NovaTech Solutions Ltd.

Enterprise Policy Framework

Business Context & Policy Reference Document

Version 2.0 | Effective: January 2025

Classification: Internal Use Only

This document is the master policy reference for NovaTech Solutions Ltd. covering all enterprise policy domains: Human Resources & Employment, Information Technology & Security, Compliance & Legal, and Operations & Vendor Management. It serves as the primary corpus for the Policy Requirement Gathering System and Full-Text Search (FTS) index within the enterprise policy management platform.

Maintained by: Policy Governance Office | policy@novatech.com

TABLE OF CONTENTS

COMPANY OVERVIEW

- 1.1 About NovaTech Solutions Ltd.
- 1.2 Business Divisions
- 1.3 Organizational Structure
- 1.4 Regulatory and Compliance Environment

PART I: HUMAN RESOURCES & EMPLOYEE POLICIES

- 2.1 Employment & Onboarding Policy
- 2.2 Code of Conduct & Ethics Policy
- 2.3 Leave & Absence Policy
- 2.4 Performance Management Policy
- 2.5 Compensation & Benefits Policy
- 2.6 Workplace Diversity, Equity & Inclusion (DEI) Policy
- 2.7 Prevention of Sexual Harassment (POSH) Policy
- 2.8 Grievance Redressal Policy
- 2.9 Remote Work & Hybrid Work Policy
- 2.10 Training & Learning Development Policy
- 2.11 Separation & Exit Policy
- 2.12 Employee Health, Safety & Wellbeing Policy

PART II: INFORMATION TECHNOLOGY & SECURITY POLICIES

- 3.1 Information Security Policy
- 3.2 Acceptable Use Policy (AUP)
- 3.3 Access Control & Identity Management Policy
- 3.4 Password & Authentication Policy
- 3.5 Data Protection & Privacy Policy
- 3.6 Network Security Policy
- 3.7 Endpoint Security Policy
- 3.8 Security Incident Response Policy
- 3.9 Application Security & Secure SDLC Policy
- 3.10 Cloud Security Policy
- 3.11 Business Continuity & Disaster Recovery Policy
- 3.12 Vulnerability Management Policy

PART III: COMPLIANCE & LEGAL POLICIES

- 4.1 Regulatory Compliance Policy
- 4.2 Anti-Bribery & Anti-Corruption (ABAC) Policy
- 4.3 Data Privacy & GDPR/DPDPA Compliance
- 4.4 Intellectual Property Policy
- 4.5 Contract Management Policy
- 4.6 Risk Management Policy
- 4.7 Internal Audit Policy
- 4.8 Whistleblower & Ethics Reporting Policy

- 4.9 Export Control & Trade Compliance
- 4.10 Records Retention & Destruction Policy

PART IV: OPERATIONS & VENDOR MANAGEMENT POLICIES

- 5.1 Procurement Policy
- 5.2 Vendor Onboarding & Due Diligence Policy
- 5.3 Vendor Contract & SLA Management Policy
- 5.4 Third-Party Risk Management (TPRM) Policy
- 5.5 IT Asset Management Policy
- 5.6 Change Management Policy
- 5.7 Project Management Policy
- 5.8 Facilities & Physical Security Policy
- 5.9 Finance & Expense Management Policy
- 5.10 Communication & Collaboration Tools Policy
- 5.11 Environmental, Social & Governance (ESG) Policy
- 5.12 Business Continuity for Operations

APPENDIX

- A.1 Policy Ownership & Review Matrix
- A.2 Key Policy Contacts
- A.3 Glossary of Key Terms
- A.4 Document Control

COMPANY OVERVIEW

1.1 About NovaTech Solutions Ltd.

NovaTech Solutions Ltd. is a multinational technology and software services company headquartered in Bengaluru, India, with regional offices in New York (USA), London (UK), Frankfurt (Germany), Singapore, and Sydney (Australia). Founded in 2004, NovaTech has grown to become a Tier-1 enterprise software and cloud services provider serving Fortune 500 clients across six continents.

The company delivers enterprise software products, cloud infrastructure, AI/ML platform solutions, cybersecurity services, digital transformation consulting, and managed IT services across industry verticals including healthcare, banking and financial services, insurance, manufacturing, retail and e-commerce, logistics, and government.

NovaTech employs approximately 12,000 full-time employees globally and engages over 3,000 contractors, freelancers, and third-party vendors. Annual revenue exceeds USD 1.2 billion. The company operates on a hybrid work model with employees across offices, client sites, and remote locations.

Keywords: NovaTech, enterprise software, cloud services, AI platform, cybersecurity, IT consulting, multinational, Bengaluru, New York, London, Frankfurt, Singapore, Sydney

1.2 Business Divisions

NovaTech operates through six primary business divisions:

- Product Engineering Division (PED): Develops NovaSuite ERP, NovaCRM, NovaAnalytics, NovaHR, and NovaSupply chain platform. ~3,500 engineers.
- Cloud & Infrastructure Division (CID): AWS, Azure, GCP deployments, DevOps, SRE, platform engineering, and cloud migration services. ~2,000 staff.
- AI & Data Science Division (ADS): ML models, NLP/LLM pipelines, computer vision, MLOps, and AI-integrated business solutions. ~1,200 staff.
- Cybersecurity Division (CSD): SOC-as-a-Service, penetration testing, vulnerability management, GRC consulting, and security tooling. ~800 staff.
- IT Consulting & Services Division (ICS): Digital transformation, ERP implementation, change management, and technology advisory. ~2,500 staff.
- Corporate & Support Functions: HR, Finance, Legal, Procurement, Facilities, Marketing, and Communications. ~2,000 staff.

Keywords: product engineering, PED, NovaSuite, NovaCRM, NovaAnalytics, cloud infrastructure, CID, AI division, ADS, cybersecurity SOC, CSD, IT consulting, ICS

1.3 Organizational Structure

NovaTech operates a matrix organizational structure. The Board of Directors (9 members, 3 independent) oversees strategy and governance. The Executive Leadership Team (ELT) comprises: CEO, CTO, CIO, CISO, CHRO, CFO, CLO, COO, and Chief Revenue Officer (CRO).

Each division is led by a Vice President (VP), with departments managed by Directors and Senior Managers. The Policy Governance Office (PGO) reports to the COO and owns the enterprise policy lifecycle.

Grade structure: Grade 1 (Analyst/Trainee) through Grade 10 (C-Suite). Grade 1-4: Individual contributors; Grade 5-6: Team leads/specialists; Grade 7-8: Senior managers/directors; Grade 9: VP; Grade 10: C-Suite.

Keywords: CEO, CTO, CIO, CISO, CHRO, CFO, CLO, COO, CRO, board of directors, organizational structure, policy governance office, grade structure, ELT, matrix organization

1.4 Regulatory and Compliance Environment

- India: Information Technology Act 2000 & Amendment 2008, Digital Personal Data Protection Act 2023 (DPDPA), SEBI (for listed entity), Payment and Settlement Systems Act.
- USA: Sarbanes-Oxley Act (SOX), HIPAA, CCPA/CPRA, FTC Act, FCPA, Export Administration Regulations (EAR).
- European Union: GDPR, NIS2 Directive, EU AI Act, ePrivacy Directive.
- UK: UK GDPR, Data Protection Act 2018, Computer Misuse Act, Cyber Essentials.
- Singapore: PDPA, MAS Technology Risk Management Guidelines, Cybersecurity Act.
- Global standards: ISO/IEC 27001:2022, ISO 9001:2015, ISO 22301:2019, SOC 2 Type II, PCI DSS v4.0, NIST CSF 2.0, CIS Controls v8.

Keywords: GDPR, HIPAA, SOX, CCPA, PDPA, ISO 27001, SOC 2, PCI DSS, NIST, NIS2, DPDPA, compliance, regulatory, data protection, EU AI Act

PART I: HUMAN RESOURCES & EMPLOYEE POLICIES

2.1 Employment & Onboarding Policy

Governs all stages from recruitment through probation confirmation. Applies to all employees, contractors, interns, and consultants globally.

2.1.1 Recruitment & Selection

- All recruitment conducted through the Talent Acquisition (TA) team; non-TA-sourced hires require CHRO exception.
- Internal job postings active minimum 7 calendar days before external posting; IJP preference for lateral moves.
- Interview panels minimum 3 members for Grade 5+; must include one HR representative.
- Background verification mandatory pre-offer: employment history (7 years), education, criminal record, global sanctions screening, and reference checks (2 professional).
- Technical assessment compulsory for Engineering, Data Science, Cybersecurity, and Product roles via HackerRank or equivalent.
- Compensation: Offers must align to published grade salary bands (revised January each year by HR Compensation team).
- Diversity shortlisting: Minimum one qualified female candidate per shortlist for Grade 5+ roles wherever pipeline permits.
- Referral bonus: Paid 90 days post-joining; both referrer and referred employee must be active; not applicable for C-Suite hires.

Keywords: recruitment, hiring, background verification, interview, technical assessment, IJP, salary band, talent acquisition, diversity shortlist, referral bonus, HackerRank

2.1.2 Onboarding & Probation

- Day 1: HR orientation, IT equipment provisioning via ITAM, Entra ID account creation, security badge issuance, payroll registration.
- Week 1 mandatory: Information Security Awareness Training, Code of Conduct acknowledgement, POSH training, Anti-Bribery training (all via LMS).

• Week 2-3: Business unit induction, role-specific system access provisioning, assigned onboarding buddy.

• Day 30 check-in: Structured 1:1 with manager and HR Business Partner; any concerns documented in HRMS.

• Day 90 probation review: Formal evaluation; confirmation or extension (max 30 additional days) or termination.

• Probation extension requires VP approval; termination during probation requires CLO and CHRO review.

Keywords: onboarding, probation, day 1, orientation, IT provisioning, Entra ID, LMS, POSH, security awareness training, probation review, confirmation, 90 day

2.2 Code of Conduct & Ethics Policy

Governs professional conduct and ethical behavior for all employees, contractors, board members, and third-party representatives. Violations may result in disciplinary action up to termination and referral to law enforcement.

• Professional integrity: Act with honesty and transparency in all dealings; never misrepresent facts to clients, management, or regulators.

• Conflicts of interest: Disclose in writing within 5 business days of becoming aware; recusal from related decisions required.

• Gifts and hospitality: Accept or give only if below INR 5,000 (or USD 60) in value; above threshold requires manager and Compliance pre-approval; record in Gifts Register.

• Political activity: Personal political activities outside working hours permitted but must not involve company resources or represent NovaTech.

• Media/Social media: Employees must not make public statements on behalf of NovaTech without Communications approval.

• Insider trading: Employees with access to material non-public information must not trade securities; trading blackout windows communicated by Legal.

• Whistleblowing: Report violations via Ethics Hotline (ethics.novatech.com) or directly to Internal Audit; anonymous reporting available.

• Non-retaliation: Retaliation against good-faith reporters is a terminable offense; subject to legal remedies.

Keywords: code of conduct, ethics, conflict of interest, gifts register, anti-bribery, whistleblower, ethics hotline, insider trading, media policy, social media, retaliation, integrity

2.3 Leave & Absence Policy

2.3.1 Leave Entitlements (India-based employees)

• Earned Leave (EL): 18 days/year; accrued at 1.5 days/month; max carry-forward 30 days; encashment at separation.

• Casual Leave (CL): 8 days/year; non-encashable; non-carryforward; cannot be combined with EL for extended leave.

• Sick Leave (SL): 12 days/year; medical certificate required for 3+ consecutive days; carryforward max 30 days.

• Maternity Leave: 26 weeks (first two births); 12 weeks (third and beyond); 8 weeks for miscarriage/medical termination.

• Paternity Leave: 10 working days within 3 months of child birth or adoption; applicable to all genders for primary caregiver adoption.

• Adoption Leave: 12 weeks (primary caregiver adopting child under 3 months).

• Bereavement Leave: 5 days (spouse, child, parent, sibling); 3 days (grandparent, in-laws); 1 day (extended family).

• Marriage Leave: 3 days (self); 1 day (sibling/child of employee).

• Exam Leave: Up to 5 days/year for accredited professional examinations; approved by manager and HR.

• Public Holidays: 10 gazetted holidays + 2 restricted holidays per NovaTech annual holiday calendar.

• Compensatory Off: For work on gazetted holidays; availed within 30 days or forfeited.

• Leave Without Pay (LWP): Granted at manager and HR discretion; affects gratuity and statutory benefit calculations.

Keywords: earned leave, casual leave, sick leave, maternity leave, paternity leave, adoption leave, bereavement leave, marriage leave, exam leave, compensatory off, LWP, holiday calendar

2.3.2 Leave Application Rules

• All leave via HRMS; EL minimum 5 days advance notice; CL minimum 1 business day advance; sick leave same day before 10 AM.

• Manager approval required for all types; HR approval for 10+ consecutive days.

• Leave during project-critical milestones: VP approval required.

• Unapproved absence 3+ consecutive days treated as abandonment; HR initiates separation process.

• Negative leave balance: Max advance leave of 5 days at manager discretion; deducted from future accruals.

Keywords: leave application, HRMS, advance notice, manager approval, negative leave balance, abandonment, unauthorized absence

2.4 Performance Management Policy

Annual cycle January–December. Evaluation: 60% goal achievement, 40% behavioral competencies across NovaTech's 5-competency model.

• Annual goal setting: Due January 31 on HRMS; SMART goals aligned to divisional OKRs and company strategy.

• Mid-year review: June 15 – July 15; progress assessment and goal re-calibration.

• Annual review: November 15 – December 15; manager rates employee; calibration session within team/department.

• Ratings scale: 5-Exceptional, 4-Exceeds Expectations, 3-Meets Expectations, 2-Needs Improvement, 1-Unsatisfactory.

• PIP (Performance Improvement Plan): Triggered for ratings 1 or 2; 90-day plan co-created by manager, employee, and HR; clear milestones and support mechanisms.

• PIP outcomes: Successful completion (re-rated 3+), extension (max 30 days), or termination with CHRO and CLO approval.

• 360-degree feedback: Mandatory for Senior Engineer (Grade 6) and above; self, peers, reports, and stakeholders.

• Promotion eligibility: Minimum 2 consecutive 'Meets Expectations' ratings; VP nomination; approved at annual calibration.

• Variable pay (bonus): Paid in March; linked to individual rating and business unit EBITDA performance.

• Annual increment: April effective date; range 0-20% based on rating and market pay position.

Keywords: performance review, PIP, performance improvement plan, annual review, goal setting, OKR, promotion, increment, variable pay, bonus, 360 feedback, rating, calibration

2.5 Compensation & Benefits Policy

Total compensation structured as Cost to Company (CTC) = Fixed Pay + Variable Pay + Statutory Benefits + Perquisites.

- Fixed Pay components: Basic Salary (40% of CTC), HRA (50% of Basic), Special Allowance, Conveyance Allowance.
- Variable Pay: 10% (Grade 1-4), 15% (Grade 5-6), 20% (Grade 7-8), 25-30% (Grade 9-10) of fixed CTC.
- Statutory: PF 12% employer, ESI (applicable for CTC < INR 21,000/month), Gratuity accrual, Professional Tax.
- Group Health Insurance: Self + spouse + 2 children + dependent parents; INR 5 lakhs base; top-up options at employee cost.
- Group Term Life Insurance: 3x annual CTC; AD&D coverage 2x CTC.
- ESOP: Grade 6+; 4-year vesting (25% per year cliff); strike price = fair market value at grant date.
- NPS: Employer contribution 10% of Basic to National Pension Scheme for enrolled employees.
- Wellness: Annual health check-up reimbursement INR 5,000; mental health EAP (Employee Assistance Program) for all employees.
- Meal card: INR 2,200/month tax-exempt meal allowance via Sodexo/Zeta.
- Internet allowance (WFH eligible): INR 1,500/month reimbursement.
- Mobile reimbursement: Grade 7+: INR 2,000/month; Grade 9+: INR 4,000/month.

Keywords: CTC, fixed pay, variable pay, HRA, PF, provident fund, ESI, gratuity, NPS, ESOP, health insurance, group term life, meal card, internet allowance, benefits, compensation

2.6 Workplace Diversity, Equity & Inclusion (DEI) Policy

- Target: 40% female representation across all grade bands by 2027; 25% female representation at Grade 7+ by 2026.
- Mandatory unconscious bias training annually for all employees; enhanced training for hiring managers.
- Persons with Disabilities (PwD): Reserved 3% of open positions; accessible office infrastructure; assistive technology provided.
- Pay equity audit: Annual third-party audit; unexplained gender pay gaps above 5% trigger immediate corrective action plan.
- Employee Resource Groups (ERGs): Women in Tech (WiT), Pride @ NovaTech, Veterans Network, NovAbility (PwD), Diversity Champions.

• Inclusive language guidelines: Published and updated annually; mandatory for all external communications.

• Diversity metrics: Published in annual ESG report; reported to Board Diversity Committee quarterly.

• Intersectionality lens applied in all DEI program design.

Keywords: DEI, diversity equity inclusion, gender pay gap, disability, PwD, ERG, unconscious bias, female representation, LGBTQ, pay equity, accessible workplace, ESG

2.7 Prevention of Sexual Harassment (POSH) Policy

Zero-tolerance policy per Sexual Harassment of Women at Workplace (Prevention, Prohibition and Redressal) Act, 2013. Extends to offices, client sites, travel, virtual meetings, and company events.

• Internal Complaints Committee (ICC): Constituted at each office with 5+ employees; Presiding Officer is senior woman employee.

• ICC composition: 1 Presiding Officer + 2 employee members (1 female) + 1 external expert (legal/NGO background).

• Complaint window: Written complaint within 3 months of incident; ICC may condone delay up to 3 more months.

• Conciliation: ICC may offer conciliation before formal inquiry at complainant's request (no monetary settlement).

• Inquiry completion: Within 90 days; findings reported to Employer within 10 days of completion.

• Interim relief: Transfer of complainant or respondent, leave, restraining order available pending inquiry.

• Penalty: Ranges from written apology to termination and legal action depending on severity.

• Annual report: ICC submits report to District Officer as required; NovaTech includes POSH statistics in Annual Report.

• Awareness: Mandatory POSH training at joining and annually; ICC conducts quarterly awareness sessions.

Keywords: POSH, sexual harassment, ICC, internal complaints committee, conciliation, inquiry, interim relief, POSH Act 2013, zero tolerance, annual report, district officer

2.8 Grievance Redressal Policy

Provides structured mechanism for employees to raise workplace concerns. All grievances documented in HRMS Grievance Module. Manager is first point of contact.

• Level 1: Direct discussion with immediate manager — 5 working days resolution target.

• Level 2: Formal grievance on HRMS to HR Business Partner — 10 working days.

• Level 3: HR Business Partner escalates to CHRO and Employee Relations — 20 working days.

• Level 4: Final appeal to CEO's office (only for cases involving senior leadership or systemic issues).

• Grievances involving the manager: Directly raised with HR Business Partner (Level 2 bypass).

• Grievances involving HR: Raised with CHRO directly.

• Confidentiality: Grievance details shared only on need-to-know basis; no information disclosed to respondent beyond what is required.

• Frivolous complaints: Complainant who knowingly files false grievances subject to disciplinary action.

• Trends: HR Analytics reviews grievance data quarterly to identify systemic issues for root cause analysis.

Keywords: grievance, HR, employee relations, HRMS, grievance redressal, escalation, CHRO, confidential, Level 1, Level 2, Level 3, appeal

2.9 Remote Work & Hybrid Work Policy

Effective January 2023. Standard hybrid: 3 anchor days in office (Tuesday, Wednesday, Thursday) per week.

• Full remote eligibility: Role-specific; approved by Division VP and HR; reviewed every 6 months.

• International remote work: Prior written approval from HR, Legal, and Finance (visa, tax, payroll implications); max 30 days per year.

• Home office requirements: Dedicated workspace, stable broadband minimum 50 Mbps, company-approved VPN mandatory when accessing corporate resources.

• Core hours: 10:00 AM – 4:00 PM local time regardless of location; async communication permitted outside core hours.

• Manager responsibilities: Minimum one in-person team meeting per month; equitable treatment of remote and in-office team members.

• WFH setup allowance: INR 15,000 one-time for eligible remote employees (approved via procurement process).

• Child/dependent care: Remote work does not substitute childcare; employees expected to maintain professional work environment.

• Data security: Restricted data must not be processed on personal devices; screen privacy filters provided for public spaces.

Keywords: remote work, hybrid work, WFH, VPN, flexible work, anchor days, international remote, work from outside India, WFH allowance, core hours, home office, data security

2.10 Training & Learning Development Policy

• Minimum 40 hours learning per employee per year (tracked on LMS); mandatory for performance evaluation.

• Individual Development Plan (IDP): Co-created with manager during annual performance cycle; linked to career path.

• Platforms: Coursera Enterprise, LinkedIn Learning, Pluralsight, O'Reilly, internal NovaTech LMS (NovaLearn).

• Certification reimbursement: Up to INR 50,000/year; AWS, Azure, GCP, PMP, CISSP, CFA, CISA, CISM, etc.; requires 70%+ score.

• Leadership Development Program (LDP): 6-month program for Grade 7+ nominated by VPs; includes executive coaching, strategy projects, mentoring.

• Graduate Hiring Program (NovaTech Campus): 12-month structured program for fresh engineering graduates.

• Mandatory annual training: Information Security, POSH, Anti-Bribery, DEI, Data Privacy, Export Controls.

• Educational assistance: Tuition reimbursement INR 1,00,000/year for accredited degree programs relevant to NovaTech's business; requires 2-year service commitment post-completion.

• Internal mentoring: NovaTech Mentorship Platform connects mentors and mentees; 6-month structured engagements.

• L&D; budget: Minimum 1.5% of annual payroll allocated to learning and development.

Keywords: training, learning development, IDP, LMS, NovaLearn, certification reimbursement, Coursera, LinkedIn Learning, Pluralsight, leadership development, campus hiring, tuition reimbursement, mentoring

2.11 Separation & Exit Policy

• Notice period: Grade 1-4: 30 days; Grade 5-6: 60 days; Grade 7-8: 90 days; Grade 9-10: 6 months.

• Notice buyout: Mutual agreement; payment equals equivalent gross salary for notice period waived.

• Garden leave: NovaTech may place employee on garden leave during notice; salary continues but duties suspended.

• Knowledge transfer: Documented KT plan submitted within 5 days of notice; approved by manager and project lead.

• Exit interview: Mandatory; conducted by HR BP; structured questionnaire plus open discussion; data used for attrition analysis.

• Full and Final settlement (FnF): Processed within 45 days of last working day; includes unpaid salary, leave encashment, gratuity (if eligible), variable pay pro-rata.

• Asset return: Laptop, access cards, mobile devices, documents on last working day; FnF withheld until clearance from IT, Finance, Admin.

• Relieving letter and experience certificate: Issued within 30 days of clearance.

• Post-employment obligations: NDA, IP assignment, non-disparagement survive employment; non-compete applicable for Grade 7+ roles per contract.

Keywords: resignation, notice period, garden leave, exit interview, full and final settlement, FnF, NDA, IP assignment, non-compete, knowledge transfer, relieving letter, gratuity, leave encashment

2.12 Employee Health, Safety & Wellbeing Policy

• Workplace safety: NovaTech complies with Factories Act 1948, Shops & Establishments Act, and local occupational health regulations.

• Ergonomics: Ergonomic assessment available for all employees; standing desks and ergonomic chairs on request via IT service desk.

• Mental health: Employee Assistance Program (EAP) provides 6 free confidential counselling sessions per employee per year.

• Occupational Health Center (OHC): On-site at headquarters; first aid and primary care available Monday–Friday.

• Accident reporting: Any workplace injury must be reported to HR and Facilities within 1 hour; serious injuries notified to labor authorities.

• Stress management: Quarterly mental health awareness workshops; manager training on identifying and supporting stressed employees.

• Substance abuse: NovaTech maintains a drug-free workplace; substance abuse assistance program available confidentially through EAP.

• Return-to-work: Structured return-to-work plans for employees on long-term sick leave exceeding 30 days.

Keywords: health safety wellbeing, EAP, mental health, ergonomics, occupational health, workplace injury, drug free, stress management, return to work, Factories Act

PART II: INFORMATION TECHNOLOGY & SECURITY POLICIES

3.1 Information Security Policy

Foundation policy for protecting all NovaTech information assets. Aligned with ISO/IEC 27001:2022 and NIST CSF 2.0. Applies to all employees, contractors, vendors.

- Data classification: Public (can be freely shared), Internal (NovaTech employees only), Confidential (limited role-based access), Restricted (need-to-know, encrypted at rest and in transit).
- Restricted data examples: Client PII, financial records, source code, security configurations, HR records, board materials.
- Information Security Management System (ISMS): Owned by CISO; scope includes all NovaTech business units and locations; certified ISO 27001 annually.
- Security risk assessments: Mandatory for all new systems, significant changes, and third-party integrations.
- Security by design (SbD): Privacy and security requirements identified at project initiation; threat modelling required for Tier 1 systems.
- Security exceptions: Formal risk acceptance process; approved by CISO; reviewed every 90 days.
- Security awareness: All employees complete annual Information Security Awareness Training; phishing simulations quarterly.

Keywords: information security, ISO 27001, NIST CSF, data classification, restricted, confidential, ISMS, CISO, security by design, threat modelling, risk assessment, security awareness

3.2 Acceptable Use Policy (AUP)

Defines permitted and prohibited use of NovaTech information systems, devices, networks, and internet. Mandatory acknowledgement at joining and annually.

3.2.1 Permitted Uses

- Company devices for business use; incidental personal use tolerated if not impacting productivity, security, or storage.
- Internet for professional development, industry research, approved SaaS tools.

• Microsoft 365 (Teams, Outlook, SharePoint, OneDrive), Jira, Confluence, GitHub Enterprise, Slack for work collaboration.

3.2.2 Prohibited Activities

• Accessing, downloading, or distributing illegal, offensive, discriminatory, adult, or extremist content.

• Using company systems for personal commercial activities, unauthorized fundraising, gambling, or cryptocurrency mining.

• Attempting to bypass, disable, or circumvent security controls, firewalls, DLP, or monitoring tools.

• Installing unauthorized software, tools, browser extensions, or scripts on company devices.

• Sharing credentials, VPN access, or system logins with any person including colleagues.

• Connecting personal storage devices (USB, external HDD) without prior IT approval and device scanning.

• Using company email for chain letters, spam, mass solicitations, or bulk marketing.

• Accessing client or company data beyond authorized role scope; unauthorized lateral movement within systems.

• Connecting non-approved devices to corporate network (wired or wireless).

Keywords: AUP, acceptable use, prohibited activities, unauthorized software, USB, credential sharing, circumvent security, crypto mining, spam, unauthorized access, DLP bypass

3.3 Access Control & Identity Management Policy

Least-privilege RBAC model enforced across all systems. All access provisioned through IAM integrated with Azure Entra ID.

• Account provisioning: HR-triggered; IAM team creates accounts within 2 business days of HR notification.

• Multi-Factor Authentication (MFA): Mandatory for all accounts; Microsoft Authenticator (TOTP) for standard; YubiKey hardware token for privileged accounts and production systems.

• Privileged Access Management (PAM): Admin accounts separate from daily-use accounts; privileged sessions recorded in CyberArk; just-in-time (JIT) access for production environments.

• Access reviews: Critical systems (production databases, cloud consoles, HR/Finance systems) every 90 days; standard systems annually.

• Role transfers: Access recertification within 5 business days; excess access revoked; new access provisioned per new role.

• Service accounts: Registered in service account registry; no interactive login permitted; passwords/keys rotated every 90 days via HashiCorp Vault.

• API keys and secrets: Managed in HashiCorp Vault or Azure Key Vault; no hardcoded credentials in code; automated rotation enforced.

• SSO: Mandatory for all approved enterprise SaaS; direct credential login to SSO-integrated apps prohibited.

• Account termination: All access revoked within 2 hours of HR separation notification; personal data archived as per retention policy.

• Guest access: External collaborators provisioned with time-limited (90-day) guest accounts via Azure B2B; must be sponsored by NovaTech employee.

Keywords: access control, RBAC, IAM, Azure AD, Entra ID, MFA, Microsoft Authenticator, YubiKey, PAM, CyberArk, JIT, privileged access, access review, SSO, HashiCorp Vault, API key, service account, guest access

3.4 Password & Authentication Policy

• Standard accounts: Minimum 14 characters; mixed case, numbers, special characters; 90-day expiry; last 12 passwords not reusable.

• Privileged accounts: Minimum 20 characters; 30-day expiry; last 24 passwords not reusable.

• Account lockout: 5 failed attempts = 30-min lockout; 10 failed attempts = alert to SOC; self-service reset via SSPR portal.

• Password manager: 1Password Enterprise provided to all employees; use mandatory for storing work credentials.

• Passphrase encouraged: 4+ random words (e.g., correct-horse-battery-staple) accepted for user accounts.

• Shared account prohibition: Individual accountability required; shared accounts permitted only for systems technically unable to support individual accounts (documented exception required).

• Biometric authentication: Permitted as second factor via FIDO2/WebAuthn compliant device; not standalone.

Keywords: password policy, authentication, 14 characters, MFA, password expiry, account lockout, 1Password, passphrase, FIDO2, WebAuthn, SSPR, shared account, biometric

3.5 Data Protection & Privacy Policy

NovaTech processes employee, client, and end-user personal data. Policy covers GDPR, DPDPA, PDPA, CCPA, and other applicable data protection laws.

- Data minimization: Collect only data necessary for specified, explicit, legitimate purpose; review collection points annually.
- Purpose limitation: Data must not be repurposed without fresh consent or new legal basis.
- Storage limitation: Retention schedules enforced; automated deletion/archival via Data Lifecycle Management (DLM) tools.
- Data subject rights response (GDPR): Access, erasure, rectification, restriction, portability — within 30 days; identity verification required.
- Data Processing Agreements (DPA): Mandatory with all processors; standard DPA template from Legal; reviewed every 2 years.
- Cross-border transfers: EU personal data transfers use SCCs; adequacy decisions used where available; BCRs in place for intra-group transfers.
- Data breach response: Detection to CISO notification within 1 hour; regulatory notification within 72 hours (GDPR); client notification per contractual SLA.
- DPIA (Data Protection Impact Assessment): Required for high-risk processing, new technology deployment, biometric processing, large-scale surveillance.
- DPO: Appointed and registered; accessible at dpo@novatech.com; independent function reporting to CLO.
- Consent management: Consent collected via OneTrust platform; withdrawal mechanism always available; consent records retained.

Keywords: data protection, privacy, GDPR, DPDPA, PDPA, CCPA, personal data, data minimization, data subject rights, erasure, DPA, SCCs, BCR, data breach, DPIA, DPO, OneTrust, consent

3.6 Network Security Policy

- Segmentation: Production, Development, Test/UAT, Corporate, Guest, and OT/IoT networks logically separated; inter-segment traffic via controlled firewall rules.
- Firewall change management: All changes via CAB process; internet-facing inbound port openings require CISO written approval; quarterly rule base review.
- Remote access: Corporate VPN (Palo Alto GlobalProtect) for traditional access; Zscaler ZPA for zero-trust application access; no split tunneling without documented exception.
- Wireless: WPA3-Enterprise for all corporate SSIDs; certificate-based authentication; guest SSID on separate VLAN with internet-only access.

• Network monitoring: 24/7 SOC monitoring via SIEM (Microsoft Sentinel); IDS/IPS (Palo Alto Threat Prevention) at all perimeters.

• DNS security: Umbrella (Cisco) DNS filtering for all endpoints and VPN traffic; malicious domain blocking.

• NAC (Network Access Control): Forescout NAC enforces device compliance before admission to corporate network.

• DDoS protection: Cloudflare DDoS mitigation for all public-facing services.

• Network vulnerability scanning: Weekly external scans (Qualys); monthly internal scans; critical findings remediated within 48 hours.

Keywords: network security, VPN, Palo Alto, Zscaler, zero trust, firewall, IDS, IPS, Microsoft Sentinel, SIEM, DNS filtering, Umbrella, NAC, Forescout, DDoS, Cloudflare, WPA3, network segmentation

3.7 Endpoint Security Policy

• Supported OS: Windows 11 (22H2+), macOS 13 Ventura+; older OS requires CISO exception and isolation network.

• EDR: CrowdStrike Falcon deployed on 100% of endpoints; real-time protection and behavioral analytics enabled.

• Disk encryption: BitLocker (Windows, TPM+PIN), FileVault 2 (macOS); recovery keys escrowed in Intune.

• MDM: Microsoft Intune for all endpoints; non-compliant devices auto-remediated or quarantined.

• BYOD: Personal devices accessing NovaTech corporate data must be enrolled in Intune MAM; jailbroken/rooted devices prohibited; device attestation required.

• Patch management: Critical CVE patches within 48 hours; high within 7 days; medium within 14 days; deployed via WSUS (Windows) and JAMF (macOS).

• USB/peripheral control: Disabled by default via Intune policy; whitelisting via IT Service Desk ticket with manager approval.

• Application control: Only approved applications from NovaTech App Store (deployed via Intune) permitted; unsigned executables blocked.

• Screen lock: 5-minute inactivity timeout; screensaver with password required.

• Full disk encryption verification: Weekly compliance scan; non-compliant endpoints reported to IT Security within 24 hours.

Keywords: endpoint security, CrowdStrike, EDR, BitLocker, FileVault, MDM, Intune, BYOD, patch management, WSUS, JAMF, USB control, application control, screen lock, disk encryption

3.8 Security Incident Response Policy

Aligned with NIST SP 800-61 Rev 2 and ISO 27035. Incident Response Team (IRT) led by CISO.

- Classification: P1-Critical (systemic breach, ransomware, nation-state attack), P2-High (contained breach, significant system compromise), P3-Medium (phishing, malware, policy violation), P4-Low (security advisory, failed intrusion attempt).
- P1 response: SOC detects and pages IRT on-call within 5 minutes; CISO, CIO, COO notified within 15 minutes; war room assembled.
- P2 response: SOC leads initial containment; management notified within 1 hour; IRT engaged.
- Containment: Isolation of affected systems within 30 minutes of P1 declaration; forensic preservation before remediation.
- Evidence preservation: Chain of custody maintained; forensic images captured before cleanup; logs preserved for 1 year minimum.
- Communication: Internal updates every 30 minutes during active P1; client notification per contract SLA; regulatory notification per applicable law.
- Post-Incident Review (PIR): P1 and P2 — mandatory within 10 business days; root cause analysis, timeline, lessons learned, corrective actions.
- Tabletop exercises: Quarterly scenario-based exercises for IRT; annual full-scale red team vs blue team exercise.
- Threat intelligence: Subscription to FS-ISAC, ISACs relevant to client verticals; threat intel fed into SIEM for automated detection rules.

Keywords: incident response, NIST 800-61, security incident, P1, P2, P3, P4, SOC, CISO, IRT, containment, forensic, evidence preservation, post-incident review, tabletop exercise, threat intelligence, SIEM

3.9 Application Security & Secure SDLC Policy

- Secure coding standards: OWASP Top 10, SANS CWE Top 25, NovaTech Secure Coding Guidelines (published on Confluence).
- Code review: All PRs require minimum 1 peer review; security-sensitive code (auth, crypto, PII handling) requires security champion review.
- SAST: SonarQube (quality) + Checkmarx (security) integrated in CI/CD pipeline (GitHub Actions); build fails on Critical/High findings.
- DAST: OWASP ZAP and Burp Suite Enterprise run against staging before every production release.

• SCA: Snyk integrated in CI/CD; OWASP Dependency-Check for Docker images; critical vulnerabilities block release.

• Container security: All Docker images built from approved base images; Trivy scan on every build; no privileged containers in production; non-root user enforced.

• API security: OAuth 2.0 / OIDC mandatory for all APIs; JWT token signing (RS256); rate limiting; input validation and output encoding; API inventory in API gateway (Azure APIM).

• Secrets management: HashiCorp Vault or Azure Key Vault; no secrets in source code (pre-commit hooks with detect-secrets); automated secret scanning in GitHub.

• Infrastructure as Code (IaC): Terraform for all cloud provisioning; Checkov and tfsec scan for security misconfigurations; direct console changes in production prohibited.

• Security training: Annual OWASP-focused secure coding training for all developers; security champions program in each engineering team.

Keywords: application security, SSDLC, OWASP, SAST, DAST, SCA, Checkmarx, SonarQube, Snyk, container security, Trivy, API security, OAuth, JWT, secrets management, Vault, IaC, Terraform, security champion

3.10 Cloud Security Policy

• CSPM: Microsoft Defender for Cloud (Azure), AWS Security Hub + GuardDuty (AWS), Security Command Center (GCP); auto-remediation for critical misconfigurations.

• IaC mandatory: Terraform for all cloud provisioning; PR-based changes only; production changes require CAB approval.

• IAM hygiene: No wildcard permissions in production; human users use SSO; service accounts use workload identity federation; root/owner accounts MFA-enforced and usage alerted.

• Encryption: All storage encrypted (AES-256); TLS 1.2+ for all data in transit; KMS with CMKs for sensitive workloads.

• Network: VPCs/VNets with private subnets for data tier; NACLs and security groups follow least-privilege; no 0.0.0.0/0 inbound rules without explicit exception.

• Logging: CloudTrail (AWS), Azure Monitor Diagnostic Logs, GCP Audit Logs centralized into Microsoft Sentinel SIEM; retention minimum 1 year.

• Public access: S3 public access blocked at account level; Azure Blob public access off by default; exceptions require CISO sign-off.

• Cost and security tagging: Mandatory tags: Environment, Project, Owner, CostCenter, DataClassification; non-compliant resources auto-tagged and owner notified.

• Cloud governance: Azure Policy, AWS Config Rules, GCP Org Policy enforce compliance guardrails; non-compliant resources auto-remediated or alerted.

• Shared responsibility model: Documented per cloud service category (IaaS, PaaS, SaaS); responsibility mapping maintained in security runbooks.

Keywords: cloud security, AWS, Azure, GCP, CSPM, Defender for Cloud, Security Hub, GuardDuty, Terraform, CMK, encryption, VPC, security group, CloudTrail, Sentinel, SIEM, cloud governance, shared responsibility

3.11 Business Continuity & Disaster Recovery Policy

• RTO/RPO tiers: Tier 1 (client-facing products, payroll, finance) RTO 4h RPO 15min; Tier 2 (internal apps, HR, procurement) RTO 24h RPO 4h; Tier 3 (archival, non-critical) RTO 72h RPO 24h.

• Backup strategy: 3-2-1 rule — 3 copies, 2 media types, 1 offsite; backups encrypted (AES-256); restoration tested quarterly.

• DR environment: Tier 1: Hot standby in secondary region (Azure West Europe / AWS eu-west-1); Tier 2: Warm standby.

• Failover testing: Automated failover test for Tier 1 systems semi-annually; full manual DR drill annually.

• BCP scope: Covers personnel, facilities, technology, supply chain, and communications; business impact analysis (BIA) annually.

• Crisis Management Team (CMT): CEO leads; CTO, CIO, CISO, CHRO, COO, CFO, CLO; communication cascade documented.

• Recovery runbooks: Step-by-step documented for each Tier 1 system; version-controlled in Confluence; practiced in DR drills.

• Cyber recovery: Immutable backups (Azure Backup with soft-delete and WORM) for ransomware protection; cyber recovery playbook distinct from standard DRP.

Keywords: business continuity, disaster recovery, BCP, DRP, RTO, RPO, backup, 3-2-1, failover, hot standby, warm standby, crisis management, BIA, ransomware, immutable backup, WORM, cyber recovery

3.12 Vulnerability Management Policy

• Vulnerability scanning: Weekly external scans (Qualys WAS); bi-weekly internal infrastructure scans; continuous cloud CSPM checks.

• CVSS scoring used for severity: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

• Remediation SLAs: Critical — 24 hours; High — 7 days; Medium — 30 days; Low — 90 days.

• Penetration testing: External application pentest annually (CREST-accredited firm); internal infrastructure pentest semi-annually; red team exercise annually.

• Bug bounty: NovaTech maintains a private bug bounty program via HackerOne for public-facing applications.

• Patch exceptions: Risk acceptance for systems where patching requires extended downtime; documented and CISO-approved; re-assessed every 90 days.

• Zero-day response: Emergency patching process activated; CISO notified immediately; interim mitigations (WAF rules, network segmentation) applied within 4 hours.

• Vulnerability metrics: Monthly vulnerability trend report to CISO; quarterly to Board Risk Committee.

Keywords: vulnerability management, Qualys, CVSS, remediation SLA, penetration testing, red team, bug bounty, HackerOne, zero day, patch exception, WAF, CREST, vulnerability scan

PART III: COMPLIANCE & LEGAL POLICIES

4.1 Regulatory Compliance Policy

- Compliance Risk Register: Maintained by Legal & Compliance; updated quarterly; maps regulations to business units.
- Compliance owners: Designated per regulatory domain; accountable for monitoring, training, testing, and reporting.
- Annual compliance audit: Led by Internal Audit; external regulatory audits facilitated by Legal.
- Regulatory horizon scanning: Monthly review of regulatory developments; CLO and CCO brief Board quarterly.
- New regulation response: Assessment within 30 days of publication; gap analysis and implementation plan within 60 days.
- Compliance violations: Self-identified violations reported to Board Audit Committee within 5 business days if material.

Keywords: regulatory compliance, compliance risk register, audit, legal, compliance owner, regulatory change, board audit committee, CCO, CLO, gap analysis

4.2 Anti-Bribery & Anti-Corruption (ABAC) Policy

Zero-tolerance policy. Complies with Prevention of Corruption Act (India), UK Bribery Act 2010, US FCPA, and applicable local laws.

- Absolute prohibition: No employee may offer, give, receive, or promise anything of value to improperly influence a business decision or government action.
- Facilitation payments: Prohibited in all circumstances, regardless of local custom or business necessity.
- Gifts and hospitality: Below INR 1,000 — no approval needed; INR 1,000 – INR 5,000 — recorded in Gifts Register with manager sign-off; above INR 5,000 — Compliance pre-approval required.
- Political contributions: Strictly prohibited in NovaTech's name without Board approval.
- Charitable donations: Require CFO and Legal sign-off; must not be tied to business outcomes or made to entities connected to public officials.
- Third-party due diligence: All agents, distributors, JV partners, and high-risk consultants screened via World-Check/Refinitiv before engagement.

• Red flag escalation: Any bribery red flags must be reported immediately to Legal or via Ethics Hotline.

• Annual ABAC training: Mandatory for all employees; enhanced training for client-facing, procurement, and finance roles.

• Consequence: Violation results in immediate termination and potential criminal referral.

Keywords: anti-bribery, anti-corruption, ABAC, FCPA, UK Bribery Act, Prevention of Corruption Act, facilitation payment, gifts register, World-Check, third-party due diligence, political contributions, criminal referral

4.3 Data Privacy & GDPR/DPDPA Compliance

NovaTech acts as both data controller and data processor depending on context. DPO appointed and registered with applicable supervisory authorities.

• Records of Processing Activities (RoPA): Maintained for all processing; updated within 30 days of new processing activities.

• Legal bases documented: Consent, Contract, Legal Obligation, Vital Interest, Public Task, Legitimate Interest — per processing purpose.

• Consent management: OneTrust CMP for website/app consent; consent records retained; withdrawal mechanism always available.

• Data subject requests: Access, erasure, rectification, portability, restriction, objection — responded to within 30 days (GDPR); 48 hours acknowledgement.

• DPIA: Required for large-scale PII processing, biometrics, profiling, automated decision-making, new surveillance technology.

• Third-party processors: Standard DPA template; SCCs for EU-to-third-country transfers; adequacy decision check before transfer.

• Breach notification: CISO within 1 hour; supervisory authority within 72 hours (GDPR); data subjects where high risk to rights and freedoms.

• DPDPA (India): Digital Personal Data Protection Act 2023 compliance program underway; consent manager registration planned; localization requirements assessed.

• Privacy by design: Privacy considerations at project design phase; privacy impact reviewed for all product features involving personal data.

Keywords: GDPR, DPDPA, DPO, RoPA, legal basis, OneTrust, data subject rights, erasure, DPIA, SCC, breach notification, privacy by design, consent management, UK GDPR, data controller, data processor

4.4 Intellectual Property Policy

• Company ownership: All IP created by employees using NovaTech resources, in connection with NovaTech's business, or during employment is owned by NovaTech.

• IP Assignment Agreement: Signed at employment commencement; covers inventions, copyrights, trademarks, trade secrets.

• Open source: MIT, Apache 2.0, BSD-2/3 licenses — freely usable; LGPL — Legal review required; GPL/AGPL/SSPL — Legal and CISO review required (copyleft risk).

• Patent management: Technical innovations disclosed to IP Committee within 30 days; committee decides filing; inventors receive recognition award.

• Trade secrets: Defined and classified; NDA with all employees, contractors, and vendors; misappropriation subject to immediate termination and legal action.

• Copyright: Software code, documentation, designs, and training materials copyrighted to NovaTech; DMCA compliance for online platforms.

• Brand assets: Use of NovaTech logos, wordmark, and brand identity governed by Brand Guidelines v3.0; external use requires Marketing Director approval.

• Client IP: Client IP provided under a license for the engagement; not used for other clients or NovaTech products without explicit written permission.

• Open source contributions: Employee contributions to external open source on personal time are permitted; contributions that derive from NovaTech IP require CLO approval.

Keywords: intellectual property, IP, patent, trademark, copyright, open source, GPL, Apache, MIT, NDA, trade secret, IP assignment, brand guidelines, DMCA, copyleft, client IP

4.5 Contract Management Policy

• Legal review: All contracts reviewed by Legal prior to execution; contracts above INR 50 lakhs require CLO sign-off.

• Standard templates: MSA, SOW, NDA, DPA, Reseller Agreement, Partner Agreement — maintained by Legal; deviations require Legal approval.

• CLM system: All executed contracts uploaded to Ironclad CLM within 5 business days of execution; searchable repository.

• Approval workflow: Automated in CLM; contract value determines approval chain (Manager → VP → CFO → CEO → Board).

• NDA: Mutual NDAs executed via DocuSign before confidential information exchange; NDA template pre-approved; custom NDAs require Legal review.

• Renewal management: Alerts at 180 and 90 days before expiry; contract owner responsible for renewal/termination decision.

• Amendment management: Same approval workflow as original contract; verbal changes have no legal effect.

• Force majeure: Standard clause in all agreements; invocation requires CLO review and written notice.

• Governing law: Default Indian law for India-sourced contracts; jurisdiction negotiated for international contracts.

Keywords: contract management, CLM, Ironclad, NDA, MSA, SOW, legal review, CLO, DocuSign, amendment, renewal, force majeure, governing law, approval workflow

4.6 Risk Management Policy

Enterprise Risk Management (ERM) framework aligned with ISO 31000 and COSO ERM 2017.

• Enterprise Risk Register: Maintained by Risk & Compliance; reviewed and updated quarterly; shared with Audit Committee.

• Risk categories: Strategic, Operational, Financial, Compliance/Regulatory, Technology/Cyber, Third-Party, Reputational, ESG.

• Risk appetite: Board-approved annually; defines maximum acceptable risk levels per category.

• Risk assessment: 5x5 likelihood-impact matrix; combined with velocity and vulnerability dimensions for technology risks.

• Risk owners: VP-level ownership for all Tier 1 risks; treatment plans with milestones and KRIs.

• New project risk: Mandatory for projects above INR 25 lakhs or 6+ months duration; integrated into Project Charter.

• KRI monitoring: Monthly; threshold breaches trigger management action and Board alert.

• Emerging risks: Annual emerging risk horizon scanning exercise; output incorporated into risk register.

• Third-party risks: Included in enterprise risk register; managed per Third-Party Risk Management Policy.

Keywords: enterprise risk management, ERM, ISO 31000, COSO, risk register, risk appetite, risk owner, KRI, risk assessment, 5x5 matrix, strategic risk, cyber risk, third-party risk, emerging risk

4.7 Internal Audit Policy

• Internal Audit Charter: Independence, objectivity, scope, authority — approved by Audit Committee; reviewed annually.

• Annual Audit Plan: Risk-based; presented to Audit Committee Q4 for following year; flexible to accommodate emerging risks.

• Audit universe: Finance, HR, Procurement, IT, Compliance, Operations, specific business units, and project audits.

• ITGC: IT general controls audit covers logical access, change management, backup and recovery, job scheduling, and incident management.

• SOC 2 Type II: Annual audit by external CPA firm; covers Security, Availability, Processing Integrity, Confidentiality, Privacy trust service criteria.

• Audit findings: Critical — Board within 5 business days; High — VP within 10 days; Medium/Low — Annual audit report.

• Management Action Plans (MAPs): Required for all findings; remediation evidenced and verified by Internal Audit.

• Continuous auditing: Automated data analytics tools (ACL Analytics) run monthly on financial transactions and access logs.

• Quality assurance: Internal Audit function subject to external quality assessment every 5 years per IIA standards.

Keywords: internal audit, audit committee, audit charter, ITGC, SOC 2, management action plan, audit plan, ACL analytics, continuous auditing, IIA standards, remediation, compliance audit

4.8 Whistleblower & Ethics Reporting Policy

• Ethics Hotline: 24/7 anonymous reporting via phone and web portal (ethics.novatech.com); managed by independent third-party.

• Channels: Ethics Hotline, direct email to Internal Audit Head, anonymous drop box at offices.

• Scope of reportable matters: Fraud, bribery, financial misconduct, safety violations, data privacy breaches, harassment, securities law violations, conflicts of interest.

• Investigation: Led by Internal Audit; CLO notified for legal matters; independent of reported business unit.

• Confidentiality: Reporter identity protected unless legally compelled to disclose.

• Non-retaliation: Policy explicitly prohibits retaliation; retaliation subject to termination; whistleblowers can seek legal remedy.

• Reporting to authorities: NovaTech cooperates with regulatory investigations; self-reporting to regulators considered where appropriate.

• Board oversight: Audit Committee reviews anonymized whistleblower report summary each quarter.

• Meritless reports: Frivolous or bad-faith reports treated as conduct matter; reporter subject to disciplinary action if malicious intent proven.

Keywords: whistleblower, ethics hotline, speak up, anonymous reporting, non-retaliation, fraud reporting, internal audit, legal investigation, ethics portal, confidentiality, securities violation, regulatory reporting

4.9 Export Control & Trade Compliance

• ECCN/EAR99 classification: All software products reviewed; encryption-enabled products assessed for export license requirement.

• Denied party screening: All new clients, partners, vendors screened against US BIS Entity List, OFAC SDN List, EU Consolidated List, and UN Sanctions List via visual compliance tool.

• Deemed export: Sharing controlled technology with foreign nationals in the US requires export license review.

• Re-export: Clients who re-export NovaTech products must comply with applicable export laws; contractual obligations included.

• Trade Compliance Officer: Designated in Legal team; maintains export training program; manages export license applications.

• Screening cadence: Existing customer/vendor list re-screened quarterly; new entities screened at onboarding.

• Violation response: Immediate suspension of transactions; CLO notified; voluntary self-disclosure to relevant authority assessed.

Keywords: export control, trade compliance, ECCN, EAR99, BIS, OFAC, sanctions, denied party, deemed export, encryption export, trade compliance officer, self-disclosure, visual compliance

4.10 Records Retention & Destruction Policy

• Retention schedule: HR records 7 years post-separation; financial records 10 years; contracts 7 years post-expiry; audit reports 10 years; email 7 years; project documentation 5 years.

• Legal hold: Triggered by litigation, regulatory investigation, or regulatory request; overrides retention schedule; managed by Legal via hold notice system.

• Retention system: Records Lifecycle Management in SharePoint with automated expiry notifications; physical records in secure storage.

• Destruction method: Electronic records — NIST 800-88 compliant cryptographic erasure or media destruction; paper records — cross-cut shredding by certified vendor.

• Data destruction certificate: Required for all hardware disposal and physical records destruction; retained for 3 years.

• Personally identifiable information (PII): Deleted/anonymized at end of retention period; not retained beyond legal minimum.

• Annual records audit: Records Management team audits compliance with retention schedule; non-compliant records flagged for remediation.

Keywords: records retention, records destruction, legal hold, retention schedule, NIST 800-88, data destruction certificate, SharePoint, records lifecycle, PII deletion, media destruction, shredding

PART IV: OPERATIONS & VENDOR MANAGEMENT POLICIES

5.1 Procurement Policy

Governs all purchases of goods, services, and technology. Principles: value for money, transparency, fairness, compliance.

- Thresholds: Below INR 25,000 — direct purchase, manager approval; INR 25,000 – INR 5 lakhs — 3 quotes, documented; INR 5 lakhs – INR 50 lakhs — formal RFQ; above INR 50 lakhs — RFP with evaluation committee.
- Purchase Orders: Mandatory for all procurements above INR 10,000; raised in NovaSuite ERP before goods/services delivery; no retrospective POs.
- Preferred Vendor List (PVL): Maintained by Procurement; standard categories sourced from PVL; deviations require Procurement Manager justification.
- Single-source justification: Procurement above INR 5 lakhs from single source requires CPO approval and documented rationale (sole provider, emergency, IP protection).
- CapEx approval: INR 50 lakhs to INR 2 crores — CFO + COO; above INR 2 crores — Board approval.
- Procurement savings: Tracked monthly; target 8% year-on-year savings on total addressable spend.
- Conflict of interest: Procurement staff must declare and recuse from any tender in which they have personal interest.
- Sustainable procurement: ESG criteria weighted minimum 10% in vendor evaluation for contracts above INR 1 crore from 2025.

Keywords: procurement, PO, purchase order, RFQ, RFP, NovaSuite ERP, preferred vendor, single source, CapEx, CPO, COO, procurement savings, conflict of interest, sustainable procurement

5.2 Vendor Onboarding & Due Diligence Policy

- Registration requirements: Business registration certificate, GST/tax ID, bank details, professional indemnity insurance, and trade references.
- Due diligence scope: Financial health (D&B Paydex score), legal entity verification, anti-corruption screening (World-Check), information security assessment (ISQ for tech vendors), reference checks (minimum 2).

• Vendor risk tiers: Critical (product-embedded, production access, processes client PII), High (significant operational dependency), Medium (standard services), Low (commodities, office supplies).

• Critical vendor ISQ: Minimum 70% score on NovaTech's 120-question Information Security Questionnaire; below threshold triggers remediation plan or disqualification.

• Conflict of interest screening: Ownership links or employment connections between vendor principals and NovaTech employees flagged; CLO review required.

• Onboarding SLA: Standard vendors 10 business days; critical vendors 20 business days (security review included).

• Vendor portal: NovaTech Vendor Portal (vendor.novatech.com) for self-service registration, document upload, and status tracking.

• Annual re-registration: All vendors re-confirm registration data annually; material changes require immediate update.

Keywords: vendor onboarding, due diligence, vendor registration, vendor risk tier, critical vendor, ISQ, security questionnaire, D&B;, World-Check, conflict of interest, vendor portal, annual re-registration

5.3 Vendor Contract & SLA Management Policy

• Contract types: MSA for strategic vendors; SOW per engagement; PO-based for transactional; Subscription Agreement for SaaS.

• SLA requirements: Availability (uptime %), response time, throughput, error rate, support response and resolution times — defined per service criticality.

• SLA measurement: Automated monitoring via ServiceNow ITSM; monthly SLA reports generated and shared with vendor.

• SLA breach penalties: Liquidated damages per contractual SLA breach table; service credits for downtime exceeding SLA threshold.

• Vendor performance review cadence: Critical vendors monthly; High vendors quarterly; Medium vendors semi-annually.

• Vendor Scorecard dimensions: Quality (40%), Cost (20%), Delivery/Timeliness (20%), Risk/Compliance (10%), Relationship/Communication (10%).

• Escalation: SLA breach escalated to vendor account manager then VP within 24 hours; persistent breaches trigger contract review.

• Termination: For convenience — 90 days notice (contracts above INR 1 crore), 30 days (smaller); for cause — immediate if material breach uncured within 15 days.

• Exit provisions: Transition assistance clause in all critical vendor contracts; minimum 6-month transition support required.

Keywords: vendor SLA, MSA, SOW, SLA breach, liquidated damages, service credit, vendor scorecard, vendor performance, termination for cause, exit provision, transition assistance, ServiceNow

5.4 Third-Party Risk Management (TPRM) Policy

• Third-Party Risk Register: All active vendors classified by risk tier; jointly maintained by Procurement, IT Security, and Legal.

• Annual reassessment: Critical and High-tier vendors reassessed annually; triggered immediately after vendor security incident or material change.

• Security reassessment: Revised ISQ, review of SOC 2 / ISO 27001 certificates, pentest report summaries, and incident history.

• Right to audit: Contractual right to audit critical vendors' security controls; exercised when risk indicators warrant; 30-day notice.

• Sub-processor approval: Critical and High vendors must notify NovaTech before engaging sub-processors that access NovaTech data; NovaTech approval required.

• Concentration risk: Procurement monitors single-vendor dependency across critical categories; threshold above 60% triggers diversification plan.

• Vendor exit planning: Critical vendors must have documented exit/transition plan; tested annually.

• Vendor BCP: Critical vendors provide BCP/DRP evidence annually; gap in vendor continuity plan is a risk register item.

• Questionnaire-free assessment: For low-risk commodities vendors, automated screening replaces manual ISQ.

Keywords: TPRM, third-party risk, vendor risk register, annual reassessment, right to audit, sub-processor, concentration risk, vendor exit plan, vendor BCP, ISQ, security certification

5.5 IT Asset Management Policy

• Asset registry: All hardware assets tagged with NovaTech asset ID; registered in ServiceNow ITAM within 24 hours of receipt.

• Hardware categories tracked: Laptops, desktops, servers, storage arrays, network switches/routers, firewalls, mobile phones, tablets, printers, projectors, peripherals.

• Software license management: All licenses tracked in ITAM; annual true-up conducted; license shortfalls addressed within 30 days to avoid vendor audit risk.

• Asset assignment: Assigned to named employee or cost center; transfers documented within 2 business days.

• Asset refresh cycles: Laptops — 3 years; desktops — 4 years; servers — 5 years; network equipment — 7 years; UPS — 7 years.

• Shadow IT detection: Endpoint management and network scanning detect unauthorized software; remediated within 5 business days.

• Disposal: IT assets disposed via certified e-waste vendor (ISO 14001 certified); NIST 800-88 data destruction; data destruction certificate filed.

• Lost/stolen device: Reported to IT Security within 1 hour; remote wipe via Intune within 2 hours; insurance claim and security incident filed.

• Software asset audit: Annual SAM (Software Asset Management) audit by external firm to assess license compliance.

Keywords: IT asset management, ITAM, ServiceNow, hardware asset, software license, SAM, shadow IT, e-waste, NIST 800-88, data destruction, Intune, remote wipe, asset refresh, lost device

5.6 Change Management Policy (ITIL-aligned)

Aligned with ITIL 4 Change Enablement practice. Governs changes to production systems, infrastructure, and cloud environments.

• Standard changes: Pre-approved, low-risk, documented procedure; no CAB required; logged in ServiceNow.

• Normal changes: Risk assessed; RFC submitted minimum 5 business days before planned date; reviewed and approved by CAB (weekly meeting).

• Emergency changes: Expedited for critical incident resolution; CTO/CISO approval within 1 hour; CAB retrospective within 2 business days.

• Change Advisory Board (CAB): Weekly; attended by IT Operations, Security, QA, and business representatives.

• Change windows: Production changes restricted to Friday 10 PM – Sunday 6 AM local server time; exceptions require COO approval.

• Rollback plan: Mandatory for all Normal and Emergency changes; tested in staging/DR environment.

• Change freeze: Code freeze 2 weeks before major product releases and during year-end financial close (December 20 – January 5).

• Post-implementation review (PIR): Required for all changes resulting in unplanned downtime or rollback.

• Change metrics: Change success rate, emergency change ratio, change-induced incidents — tracked monthly by IT Operations.

Keywords: change management, ITIL, CAB, change advisory board, RFC, standard change, normal change, emergency change, rollback, change window, change freeze, post-implementation review, ServiceNow

5.7 Project Management Policy

• Project initiation: Projects above INR 25 lakhs require Project Charter approved by sponsoring VP and PMO.

• Methodology: Agile Scrum/Kanban for software products; PRINCE2/PMI for infrastructure and compliance; hybrid permitted with PMO approval.

• PMO oversight: All Tier 1 (above INR 1 crore or strategic) and Tier 2 (above INR 25 lakhs) projects; portfolio dashboard reported to COO monthly.

• Governance: Steering committee for Tier 1 projects (VP sponsors, CFO, CTO/CIO); monthly steering reviews.

• Resource management: Resource requests via HRMS Resource Management; skills matrix for allocation; utilization target 80-85% billable.

• Budget: Monthly budget vs actuals; variance above 10% requires VP notification; above 20% requires CFO review and re-baseline.

• Risk and issue log: Maintained throughout lifecycle; risks above threshold escalated to steering committee.

• Quality gates: Defined per methodology; mandatory for phase transitions in waterfall; definition of done in Agile.

• Project closure: Lessons learned, benefits realization plan, project asset archival, stakeholder sign-off; benefits tracked 6 months post-go-live.

• Project management tools: Jira (Agile), Microsoft Project (traditional), Confluence (documentation), Power BI (PMO dashboard).

Keywords: project management, PMO, Project Charter, Agile, Scrum, Kanban, PRINCE2, PMI, steering committee, resource management, budget variance, quality gate, lessons learned, Jira, Confluence

5.8 Facilities & Physical Security Policy

• Access control: HID card readers at all entry/exit points; visitor management system (Envoy VMS) at reception; turnstile/mantrap at high-security areas (server rooms, finance floor).

• Visitor policy: Pre-registered or walk-in with government ID; Envoy VMS badge issued; NovaTech escort at all times in secure zones.

• CCTV: Hikvision IP cameras with 90-day retention; monitored 24/7 by security operations; privacy notices posted.

• Clean desk: Mandatory at day-end; monitors locked; paper documents in locked drawer or shredded; NovaTech-branded privacy screens provided.

• Server room: Biometric access (fingerprint + card); temperature/humidity monitoring with alerts; FM-200 fire suppression; UPS and generator for power continuity.

• Physical media: Sensitive printouts shredded on-site with cross-cut shredder; removable media destruction via certified vendor.

• Security personnel: Uniformed guards at all major offices; incident report to Facilities Manager within 15 minutes.

• Emergency: Evacuation maps at all exits; designated assembly points; fire drill semi-annually; first aider per 50 employees.

• Tailgating prevention: Anti-tailgating training; security alerts for tailgating incidents; physical barriers at entry.

Keywords: physical security, HID, access control, Envoy VMS, visitor management, CCTV, Hikvision, clean desk, server room, biometric, FM-200, fire suppression, emergency evacuation, tailgating, shredder

5.9 Finance & Expense Management Policy

• Annual budget cycle: Business unit proposals by September 30; CFO consolidation by October 31; Board approval by November 30.

• Travel booking: All business travel booked through approved TMC (MakeMyTrip Corporate); personal bookings not reimbursed.

• Air travel class: Domestic — economy; international below 6 hours — economy; international above 6 hours — business class for Senior Manager+ roles.

• Hotel: Tier 1 cities (Bengaluru, Mumbai, Delhi, Singapore, New York, London) — INR 8,000/night; Tier 2 — INR 5,000/night; international per published rate card.

• Per diem: Domestic INR 2,000/day meals; international as per IRS per diem rates.

• Expense submission: Within 10 calendar days of travel or expense incurrence via Concur Expense; receipts required for all items above INR 500.

• Approval: Manager up to INR 10,000; Finance Controller up to INR 1 lakh; CFO above INR 1 lakh.

• Prohibited expenses: Personal items, alcohol (unless client entertainment with VP approval), fines, penalties, non-business entertainment.

• Corporate cards: Issued to Grade 7+; monthly reconciliation by 5th of following month; misuse = card cancellation + disciplinary action.

• Advance: Travel advance available via HRMS; must be settled within 15 days of return.

Keywords: finance policy, expense management, budget, travel booking, MakeMyTrip, air travel class, per diem, Concur Expense, corporate card, advance, expense approval, hotel policy, MIS report

5.10 Communication & Collaboration Tools Policy

• Approved enterprise tools: Microsoft Teams (voice, video, messaging), Outlook (email), SharePoint (intranet/document management), OneDrive (personal file storage), Jira (project tracking), Confluence (knowledge base), GitHub Enterprise (source code), Slack (engineering teams).

• Data residency: Microsoft 365 India tenancy for India-based employees; regional tenancies for US/EU staff; enforced per data sovereignty requirements.

• External sharing: SharePoint external sharing requires manager approval; Restricted classified data must not leave NovaTech systems without Legal review.

• Email encryption: S/MIME encryption optional; Restricted data attached to email must be encrypted separately; DLP policies in Microsoft Purview block Restricted data leaving corporate email.

• Teams meeting recording: All participants notified before recording; recordings in OneDrive; retained 90 days (extended to 7 years if meeting contains contractual discussions).

• Email retention: Business-critical emails retained 7 years per Records Retention Policy; eDiscovery and legal hold via Microsoft Purview.

• Instant message retention: Teams and Slack messages 1 year standard; subject to legal hold override.

• Prohibited: Business communication on personal Gmail, WhatsApp, WeChat, or social media.

• AI tools: Approved AI tools list published quarterly; unapproved AI tools (including public LLMs) must not process NovaTech or client data.

Keywords: collaboration tools, Microsoft Teams, Outlook, SharePoint, OneDrive, Jira, Confluence, GitHub, Slack, data residency, DLP, Purview, email retention, meeting recording, eDiscovery, AI tools policy

5.11 Environmental, Social & Governance (ESG) Policy

• Carbon neutrality: Net-zero Scope 1 and Scope 2 by 2035; Scope 3 reduction plan by 2030; interim target 50% reduction by 2028.

• Renewable energy: 100% renewable electricity for owned offices by 2027; PPAs and RECs as instruments.

• Energy monitoring: Monthly energy consumption tracking per facility; efficiency initiatives coordinated by Sustainability team.

• Water: Water usage monitored; water recycling systems installed at headquarters; zero liquid discharge target for owned facilities.

• E-waste: 100% responsible disposal through ISO 14001 certified recyclers; zero e-waste to landfill target from 2024.

• CSR: 2% net profit per Companies Act 2013; focus areas: STEM education for girls, digital literacy for rural communities, healthcare access.

• Supplier ESG: ESG criteria (10% weight) in vendor evaluation for contracts above INR 1 crore from 2025; supplier code of conduct signed by all vendors.

• Board governance: Min 30% independent directors; ESG Committee of Board established (Chair: Independent Director); diversity target on Board.

• ESG reporting: Annual ESG report following GRI Standards and BRSR (Business Responsibility and Sustainability Reporting); third-party verified.

• Employee ESG engagement: Sustainability ambassadors network; annual green initiatives campaign; ESG goals linked to VP+ variable pay from 2025.

Keywords: ESG, sustainability, carbon neutral, net zero, Scope 1 Scope 2 Scope 3, renewable energy, PPA, REC, water management, e-waste, CSR, supplier ESG, board governance, GRI, BRSR, ESG reporting

5.12 Business Continuity for Operations

• Operational resilience: Critical business processes identified in BIA; manual workarounds documented for all Tier 1 processes.

• Supply chain continuity: Dual-source strategy for all critical hardware components; minimum 90-day inventory buffer for critical parts.

• Third-party dependency map: All critical vendor single points of failure identified; mitigation plans in Third-Party Risk Register.

• Pandemic/crisis preparedness: Remote work capability verified for 100% of roles; communication cascade plan tested annually.

• Financial resilience: Liquidity reserves covering 6 months of operating expenses; credit facility with consortium of banks.

• Facilities resilience: Generator backup for all primary offices (minimum 48-hour fuel supply); UPS coverage for server rooms and critical workstations.

• Annual BCP test: Full operational continuity test including real activation of alternate sites, remote work, and backup systems.

Keywords: operational resilience, BCP, business continuity, BIA, supply chain continuity, dual source, pandemic preparedness, financial resilience, generator, UPS, facilities resilience, annual test

APPENDIX: POLICY QUICK REFERENCE

A.1 Policy Ownership & Review Matrix

Policy / Domain	Owner	Approver	Review Freq.
HR & Employment (all sub-policies)	CHRO	CEO	Annual
Code of Conduct & Ethics	CLO / CHRO	CEO	Annual
POSH	CHRO / ICC	CHRO	Annual + triggered
Information Security (ISMS)	CISO	Board Risk Committee	Annual
AUP / Acceptable Use	CISO	CIO	Annual
Access Control / IAM	CISO	CIO	Annual
Incident Response	CISO	CIO	Annual
Application Security / SSDLC	CISO / CTO	CTO	Annual
Cloud Security	CISO / CID VP	CIO	Annual
Vulnerability Management	CISO	CIO	Annual
BCP / DR	CIO / COO	CEO	Annual
Data Privacy / GDPR / DPDPA	DPO / CLO	CLO	Annual + triggered
Anti-Bribery / ABAC	CCO / CLO	Board Audit Committee	Annual
Intellectual Property	CLO	CLO	Annual
Contract Management	CLO	CLO	Annual
Risk Management (ERM)	CCO / CFO	Board Risk Committee	Annual
Internal Audit	Head Internal Audit	Audit Committee	Annual
Whistleblower / Ethics	Head Internal Audit	Audit Committee	Annual
Export Controls	CLO / TCO	CLO	Annual
Records Retention	CLO / CIO	CLO	Annual
Procurement	CPO	COO	Annual
Vendor Onboarding / TPRM	CPO / CISO	COO	Annual
IT Asset Management	CIO	CIO	Annual
Change Management	CIO	CTO	Annual
Project Management	PMO Director	COO	Annual
Physical Security / Facilities	VP Facilities	COO	Annual
Finance & Expense	CFO	Board Finance Cmte.	Annual
Collaboration Tools	CIO	CTO	Annual
ESG	COO / CLO	ESG Board Committee	Annual

A.2 Key Policy Contacts

• Policy Governance Office: policy@novatech.com | +91-80-XXXX-XXXX

• HR Help Desk: hrhelp@novatech.com | Ext. 1001

• IT Service Desk: servicedesk@novatech.com | +91-80-XXXX-XXXX | 24/7

• Ethics & Compliance Hotline: ethics.novatech.com | 1800-XXX-XXXX | 24/7 Anonymous

• Data Protection Officer: dpo@novatech.com

• Legal & Contracts: legal@novatech.com

• Procurement: procurement@novatech.com

• Security Incidents (SOC): security@novatech.com | +91-80-XXXX-XXXX | 24/7

• Vendor Management: vendors@novatech.com

• ESG / Sustainability: sustainability@novatech.com

Keywords: contact, policy office, HR helpdesk, IT service desk, ethics hotline, DPO, legal, procurement, security incident, SOC, vendor management, sustainability

A.3 Glossary of Key Terms

• CISO: Chief Information Security Officer — executive responsible for information security strategy and operations.

• CHRO: Chief Human Resources Officer — executive responsible for people strategy, HR, and employee experience.

• CLO: Chief Legal Officer — executive responsible for legal, compliance, and corporate governance.

• DPO: Data Protection Officer — independent officer responsible for data privacy compliance (GDPR/DPDPA).

• CCO: Chief Compliance Officer — leads regulatory compliance program.

• ISMS: Information Security Management System — framework for managing information security (ISO 27001).

• IAM: Identity and Access Management — systems and processes for managing user identities and access rights.

• PAM: Privileged Access Management — controls and monitoring for accounts with elevated system privileges.

• SSDLC: Secure Software Development Life Cycle — integrates security into every phase of software development.

• TPRM: Third-Party Risk Management — processes for identifying and managing risks from vendor and partner relationships.

• ERM: Enterprise Risk Management — holistic framework for identifying and managing risks across the organization.

• BCP: Business Continuity Plan — documented plan to maintain critical operations during and after disruptions.

• DRP: Disaster Recovery Plan — procedures to recover IT systems and data after a disaster.

• RTO: Recovery Time Objective — maximum acceptable downtime after a disruption.

• RPO: Recovery Point Objective — maximum acceptable data loss measured in time.

• PIP: Performance Improvement Plan — structured plan to address underperformance.

• FTS: Full-Text Search — database search technique indexing all words in documents for keyword-based retrieval.

Keywords: CISO, CHRO, CLO, DPO, CCO, ISMS, IAM, PAM, SSDLC, TPRM, ERM, BCP, DRP, RTO, RPO, PIP, FTS, glossary, definitions

A.4 Document Control

This document is controlled under NovaTech's Document Management Policy. The Policy Management System (PMS) is the system of record. All policy updates are communicated to affected employees via HRMS notification and company-wide email. Major revisions (version X.0) require Board or delegated authority approval. Minor revisions (version X.1, X.2) require CLO or relevant function head approval. Policy acknowledgement recorded in HRMS for all mandatory policies. Employees hired after effective date must acknowledge within 30 days of joining. Hard copies are uncontrolled; always refer to intranet PMS for current version.

Keywords: document control, policy management system, PMS, version control, policy acknowledgement, intranet, major revision, minor revision, HRMS notification, effective date

PART V: POLICY IMPLEMENTATION SCENARIOS & EXAMPLES

6.1 HR Policy Scenarios & Application Examples

This section provides common policy application scenarios to assist employees and managers in understanding how NovaTech policies apply in real-world situations. These examples guide the policy

requirement gathering process.

6.1.1 Leave Policy Scenarios

• Scenario: Employee applies for 20 consecutive days of EL for a family event. Required: Manager approval + HR approval (exceeds 10 days). VP approval required if during project delivery milestone.

• Scenario: Employee falls sick without prior notice. Action: Submit sick leave on HRMS on same day before 10 AM; medical certificate required if absence exceeds 3 consecutive days.

• Scenario: Employee runs out of EL and CL balance. Options: LWP (Leave Without Pay) with manager and HR approval; advance EL up to 5 days at manager discretion; deducted from future accruals.

• Scenario: Female employee requires maternity leave. Entitlement: 26 weeks (first two births); can be extended 4 weeks for medical complications on physician's certification; adoption leave provisions apply for adoption cases.

• Scenario: Employee works on a gazetted holiday for a critical project release. Entitlement: Compensatory off accrued; must be availed within 30 days; not encashable; VP approval needed for work on holiday.

• Scenario: Employee requests remote work from a country outside India for 6 weeks. Required: HR, Legal, and Finance approval; tax and visa risk assessment; maximum 30 days per year per standard policy; exceptions require CHRO sign-off.

Keywords: leave scenarios, sick leave, maternity leave, compensatory off, LWP, advance leave, work from abroad, EL application, remote work scenario

6.1.2 Performance Management Scenarios

• Scenario: Manager needs to place an employee on PIP. Steps: Discuss concerns in writing, formal PIP with SMART milestones, HR Business Partner involvement, 90-day plan, bi-weekly check-ins, outcome decision after 90 days.

• Scenario: Employee disagrees with performance rating. Process: Discuss with manager; if unresolved, escalate via HRMS Grievance Module to HR Business Partner; calibration committee review as final recourse.

• Scenario: Employee achieves exceptional results and is recommended for promotion. Requirements: 2 consecutive 'Meets Expectations' ratings minimum, VP nomination, calibration session approval, compensation review by HR.

• Scenario: Mandatory 360-degree feedback for a Senior Engineer. Process: Self-assessment submitted on HRMS; 5-8 peers/stakeholders nominated; HR Business Partner facilitates; results shared in development discussion.

Keywords: PIP scenario, performance disagreement, promotion process, 360 feedback, calibration, HRMS, manager, HR business partner

6.1.3 Code of Conduct Scenarios

- Scenario: Employee receives a gift worth INR 6,000 from a vendor. Action required: Disclosure to manager and Compliance team; gift must be declined or surrendered to company; recorded in Gifts Register.
- Scenario: Employee discovers a colleague is sharing code with a competitor. Action: Immediately report via Ethics Hotline or directly to Internal Audit; do not confront the colleague directly; reporter protected by non-retaliation policy.
- Scenario: Employee is offered a freelance consulting role with a client of NovaTech. Action: Disclose potential conflict of interest to manager and HR in writing within 5 business days; await written approval before accepting.

Keywords: gift scenario, conflict of interest, ethics reporting, IP misappropriation, freelance conflict, code of conduct application, vendor gift, insider trading scenario

6.2 IT & Security Policy Scenarios & Implementation Examples

Common scenarios illustrating how IT and security policies apply in day-to-day engineering and operations contexts.

6.2.1 Access Management Scenarios

- Scenario: New developer joining a project needs access to production database. Process: Access request via ServiceNow with manager approval; CISO/Security team review; JIT access via CyberArk PAM; session recorded; quarterly review of access.
- Scenario: Employee transfers from Product Engineering to Cybersecurity division. Action: HR notifies IAM team; existing PE access recertified within 5 business days; new CSD access provisioned per new role; excess access revoked.
- Scenario: Employee laptop is lost during business travel. Action: Report to IT Security within 1 hour; IT Security triggers remote wipe via Intune within 2 hours; HR notified; IT Service Desk issues replacement within 24 hours; insurance and security incident filed.
- Scenario: Contractor engagement ends. Action: HR sends separation notice; IAM team revokes all access within 2 hours; ServiceNow automated off-boarding workflow triggered; contractor equipment returned and wiped.

Keywords: access provisioning scenario, production access, role transfer, lost laptop, contractor off-boarding, Intune, CyberArk, IAM workflow, JIT access, remote wipe

6.2.2 Development Security Scenarios

• Scenario: Developer discovers hardcoded AWS access key in a Git commit. Action: Immediately rotate the key in AWS IAM; invalidate old key; remove from code history via git-filter-repo; notify CISO; run detect-secrets pre-commit hook to prevent recurrence.

• Scenario: SAST scan reports a Critical SQL injection vulnerability in a release candidate. Action: Build is blocked in CI/CD pipeline; assigned to developer for immediate remediation; re-scanned before release; no CISO exception for Critical findings on externally-facing APIs.

• Scenario: Team wants to use a new open-source library with an AGPL license. Action: Refer to IP Policy; AGPL is copyleft — requires Legal and CISO review before use; alternative MIT/Apache licensed library preferred.

• Scenario: Penetration test reveals an authentication bypass vulnerability. Action: P2 security incident created; immediate patch deployed to staging within 24 hours; production deployment post-CAB; pentest firm re-validates fix; PIR completed within 10 business days.

Keywords: hardcoded secret, AWS key rotation, SAST finding, SQL injection, AGPL license, penetration test finding, authentication bypass, CI/CD security gate, security remediation scenario

6.2.3 Incident Response Scenarios

• Scenario: SOC detects anomalous login from an unrecognized country on an employee account. P3 incident: Account disabled pending investigation; employee notified; phishing or credential compromise investigated; password reset and MFA re-enrolment required before account restored.

• Scenario: Ransomware detected on 3 endpoints in the finance department. P1 incident: Endpoints isolated from network immediately; IRT assembled; CISO, CIO, COO notified within 15 minutes; backup restoration initiated; forensic investigation launched; legal, HR, and Communications teams engaged.

• Scenario: Vendor reports a breach that may have exposed NovaTech client data. P1 incident: CISO and CLO notified immediately; vendor's incident report obtained; NovaTech forensic team assesses scope; data subjects notified if confirmed; regulatory notification assessed (72-hour GDPR clock starts on confirmation).

Keywords: incident scenario, anomalous login, ransomware response, vendor breach, P1 incident, P3 incident, account compromise, data subject notification, forensic investigation, GDPR 72 hours

6.3 Compliance & Legal Policy Scenarios

Guidance on compliance situations that commonly arise in NovaTech's business operations.

6.3.1 Data Privacy Scenarios

• Scenario: Customer submits a GDPR erasure request (right to be forgotten). Process: Acknowledge within 48 hours; identity verification; assess legal grounds for retention (legal obligation, legitimate interest); if no grounds — erase from all systems within 30 days; inform customer of completion; log in OneTrust.

• Scenario: NovaTech plans to integrate a new analytics tool that profiles user behaviour at scale. Required: DPIA mandatory (large-scale profiling); DPO review; legal basis assessed; privacy notice updated; Data Processing Agreement with the analytics vendor; Board CISO briefed if Restricted data involved.

• Scenario: Employee in Germany asks what personal data NovaTech holds about them. Process: GDPR Article 15 Subject Access Request; acknowledge within 48 hours; collate data from HRMS, email, Slack, expense system; provide structured report within 30 days; redact third-party data.

Keywords: GDPR erasure, right to be forgotten, subject access request, DPIA, analytics profiling, data subject rights, OneTrust, privacy notice update, SAR Germany, DPO review

6.3.2 Procurement & Vendor Scenarios

• Scenario: Business unit wants to engage a new software vendor for a business-critical SaaS tool that will process client PII. Process: Vendor risk classification as Critical; full due diligence (financial, legal, security ISQ); DPA execution; GDPR adequacy check for data transfer; CISO approval; Legal review of contract.

• Scenario: Procurement receives only one qualified bid for a specialised security consulting project worth INR 1 crore. Action: Single-source justification document prepared; CPO approval obtained; documented rationale (sole provider of specialised expertise); Legal review of contract; risk noted in procurement register.

• Scenario: A critical vendor's ISO 27001 certificate has expired. Action: Vendor notified; remediation timeline obtained; interim compensating controls assessed; if renewal delayed beyond 60 days — escalate to CISO and consider contract remedies; vendor risk register updated.

Keywords: critical vendor onboarding, PII vendor, single source justification, vendor ISO 27001 expired, CPO approval, DPA, GDPR adequacy, vendor remediation, contract risk

6.4 Policy Request Types & Requirement Gathering Guide

This section serves as a structured guide for the Policy Requirement Gathering System. When a user submits a policy creation or modification request, the system should gather the following contextual data

points to generate an accurate, compliant policy document.

6.4.1 New Policy Creation — Required Context

- Policy domain: HR / IT & Security / Compliance & Legal / Operations & Vendor Management.
- Policy type: Operational procedure / Governance policy / Technical standard / Regulatory compliance procedure.
- Scope: Which employee categories, locations, or systems does the policy apply to?
- Trigger: What business need, incident, audit finding, or regulatory change is driving this new policy?
- Approver: Which executive or committee must approve (refer to Policy Ownership Matrix in Appendix A.1)?
- Related policies: Does this policy interact with or supersede any existing NovaTech policies?
- Regulatory alignment: Which laws or standards must this policy comply with (GDPR, ISO 27001, POSH Act, etc.)?
- Enforcement: What are the consequences for non-compliance, and who enforces them?
- Effective date and review cycle.

Keywords: policy creation, requirement gathering, policy domain, policy type, scope, trigger, approver, regulatory alignment, enforcement, effective date

6.4.2 Policy Modification — Required Context

- Existing policy reference: Policy number and name as in the Policy Management System (PMS).
- Change type: Minor update (wording/clarification), Major revision (structural/scope change), Regulatory-driven update, Post-incident update.
- Specific sections to change: Quote the existing text and describe the required change.
- Justification: Why is this change needed? (Regulatory change, audit finding, incident, business change, periodic review.)
- Impact assessment: Which employee groups, systems, or processes are affected by the change?
- Communication plan: How will affected employees be notified of the change?
- Effective date: Immediate or phased rollout?

Keywords: policy modification, policy update, change type, existing policy, PMS, regulatory update, impact assessment, communication plan, phased rollout, minor update, major revision

6.4.3 Common Policy Requirement Keywords by Domain

The following keyword clusters help the requirement gathering system identify the correct policy domain and sub-policies to reference or generate:

- HR domain keywords: hiring, recruitment, onboarding, probation, leave, attendance, performance, PIP, promotion, increment, bonus, benefits, resignation, termination, notice period, NDA, training, learning, DEI, POSH, harassment, grievance, remote work, hybrid.
- IT & Security keywords: access, password, MFA, VPN, encryption, firewall, endpoint, patch, vulnerability, incident, breach, phishing, malware, ransomware, cloud, AWS, Azure, GCP, API, authentication, RBAC, IAM, SAST, DAST, pentest, backup, DR, BCP.
- Compliance & Legal keywords: GDPR, data privacy, personal data, DPA, NDA, contract, IP, patent, trademark, copyright, audit, risk, anti-bribery, corruption, gift, whistleblower, export, sanctions, records retention, legal hold.
- Operations & Vendor keywords: procurement, purchase order, vendor, supplier, SLA, MSA, SOW, due diligence, onboarding, risk tier, third party, asset, change management, project, facilities, expense, travel, budget, ESG, sustainability.

Keywords: policy keywords, domain keywords, HR keywords, IT security keywords, compliance keywords, vendor management keywords, requirement gathering, keyword classification, policy domain mapping